IDOR

What's an IDOR ?

IDOR là viết tắt của Insecure Direct Object Reference (Tham chiếu đối tượng trực tiếp không an toàn) và là một loại lỗ hổng kiểm soát truy cập.

Loại lỗ hổng này có thể xảy ra khi máy chủ web nhận dữ liệu do người dùng cung cấp để truy xuất các đối tượng (tệp, dữ liệu, tài liệu), người dùng quá tin tưởng vào dữ liệu đầu vào và dữ liệu đó không được xác thực ở phía máy chủ để xác nhận đối tượng được yêu cầu thuộc về người dùng yêu cầu nó.

1. Finding IDORs in Encoded Ids

Encoded Ids

Khi truyền dữ liệu từ trang này sang trang khác bằng dữ liệu POST, chuỗi truy vấn hoặc cookie, các nhà phát triển web thường sẽ mã hóa dữ liệu thô trước. Mã hóa đảm bảo rằng máy chủ web nhận dữ liệu có thể hiểu được nội dung. Mã hóa chuyển đổi dữ liệu nhị phân thành chuỗi ASCII, thường sử dụng các ký tự a-z, A-Z, 0-9 và = để đệm. Kỹ thuật mã hóa phổ biến nhất trên web là mã hóa base64 và thường khá dễ nhận biết. Chúng ta có thể sử dụng các trang web như https://www.base64decode.org/ để giải mã chuỗi, sau đó chỉnh sửa dữ liệu và mã hóa lại bằng https://www.base64encode.org/.

What is a common type of encoding used by websites?

base64 ✓ Correct Answer

2. Finding IDORS in Hashed IDs

Hashed IDs

Mã định danh được băm (hashed ID) phức tạp hơn một chút so với mã định danh được mã hóa (encoded ID), nhưng chúng có thể tuân theo một mẫu có thể dự đoán được, chẳng hạn như là phiên bản băm của giá trị số nguyên. Ví dụ, mã định danh 123 sẽ trở thành 202cb962ac59075b964b07152d234b70 nếu sử dụng thuật toán băm MD5.

Việc sử dụng bất kỳ mã băm nào được tìm thấy thông qua một dịch vụ web như https://crackstation.net/(mở trong tab mới) (nơi có cơ sở dữ liệu gồm hàng tỷ kết quả chuyển đổi mã băm sang giá trị) để xem có tìm thấy kết quả trùng khớp nào không.

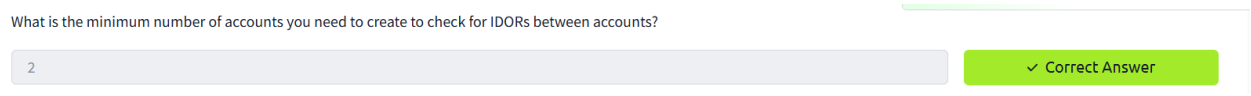
What is a common algorithm used for hashing IDs?

md5 ✓ Correct Answer

3. Finding IDORs in Unpredictable IDs

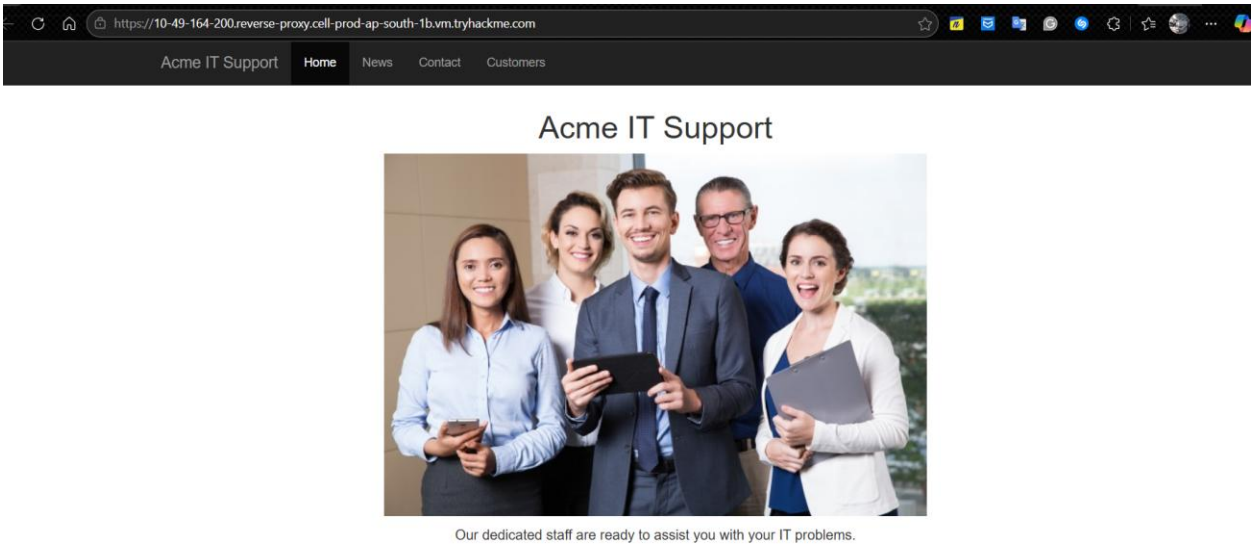
Unpredictable IDs

Nếu không thể phát hiện ID bằng các phương pháp trên, một phương pháp phát hiện IDOR hiệu quả là tạo hai tài khoản và hoán đổi số ID giữa chúng. Nếu ta có thể xem nội dung của người dùng khác bằng số ID của họ trong khi vẫn đang đăng nhập bằng một tài khoản khác (hoặc thậm chí không đăng nhập), bạn đã tìm thấy một lỗ hổng IDOR hợp lệ.

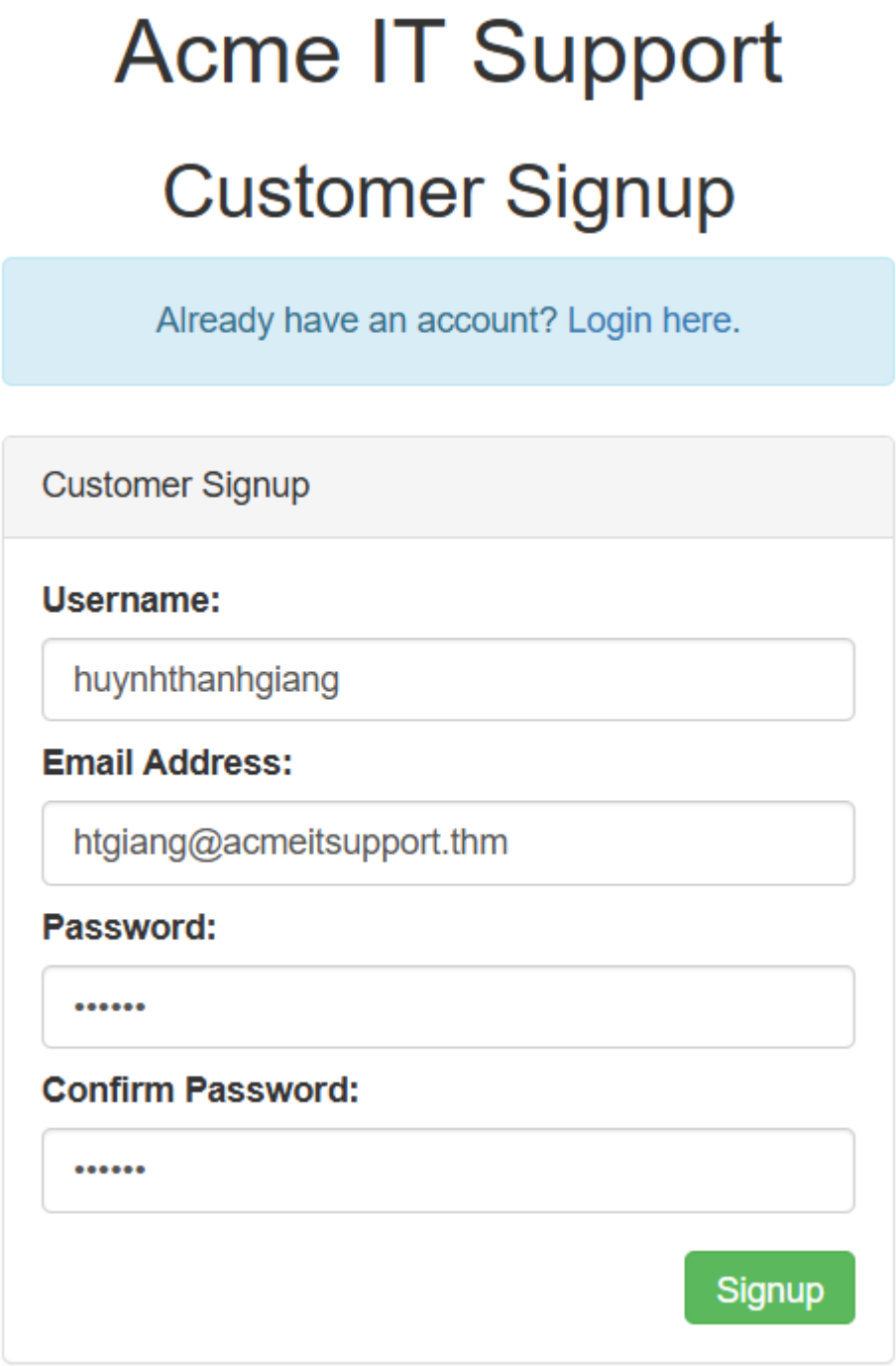


4. A Practical IDOR Example

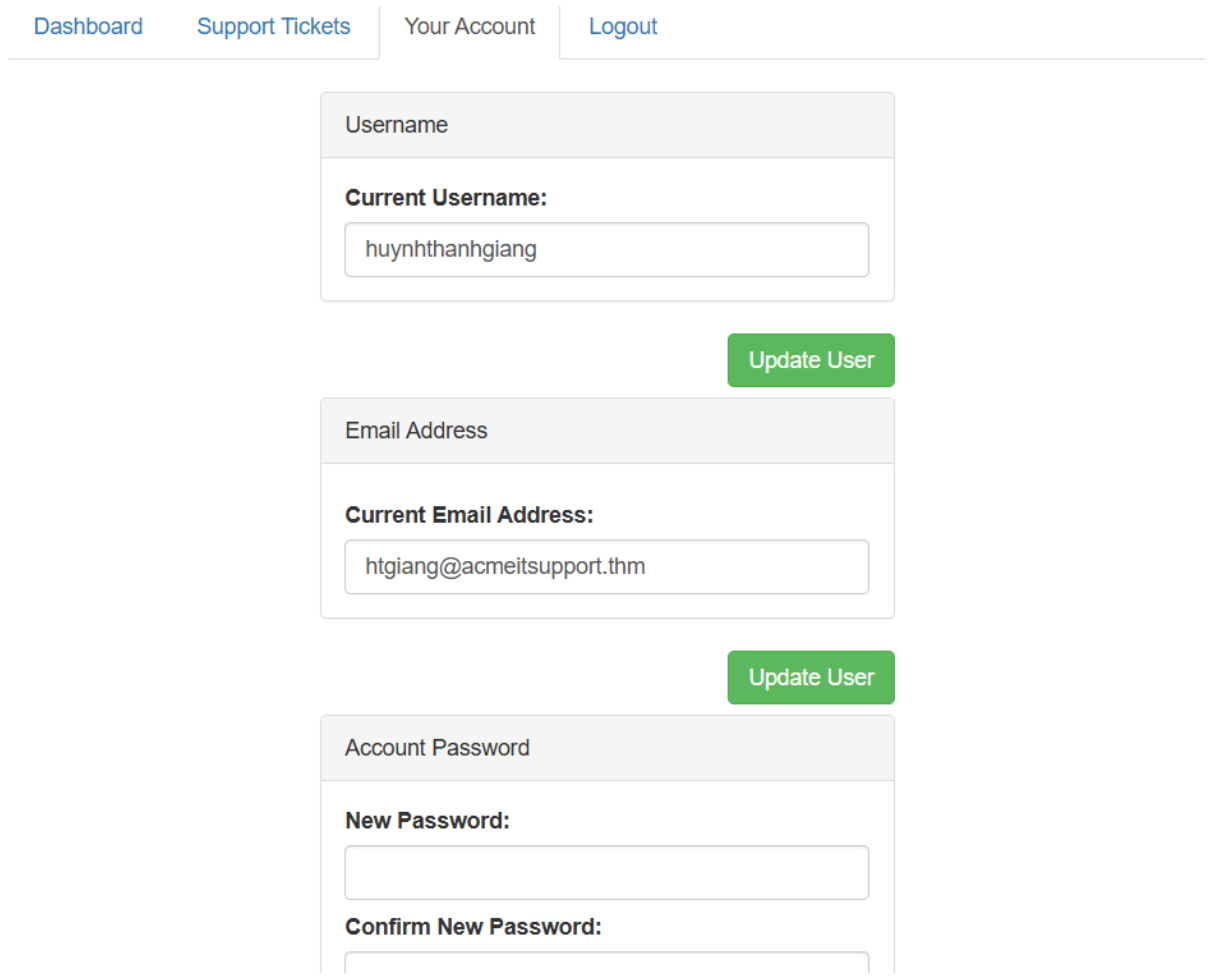
Chúng ta sẽ sử dụng trang web được cung cấp bởi tryhackme.



Trước tiên, chúng ta nhấp vào mục khách hàng và tạo tài khoản. Sau khi đăng nhập, hãy nhấp vào tab **Your account.**



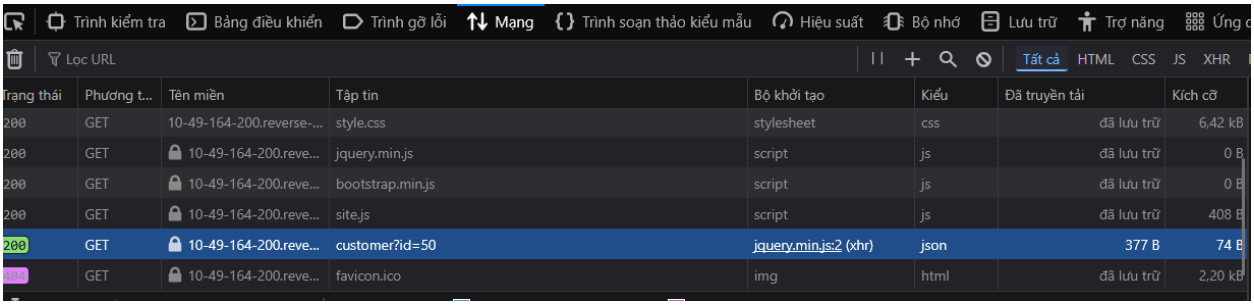
Tab **Your account** cho phép ta thay đổi thông tin của mình như tên người dùng, địa chỉ email và mật khẩu. Ta sẽ thấy các trường tên người dùng và email được điền sẵn thông tin của chúng ta.



Chúng ta sẽ bắt đầu bằng cách tìm hiểu cách thông tin này được điền sẵn. Nếu ta mở **Developer Tools**, chọn tab Network và sau đó làm mới trang, bạn sẽ thấy một lệnh gọi đến điểm cuối với đường dẫn /api/v1/customer?id={user_id}.

Trang này trả về ID người dùng, tên người dùng và địa chỉ email của bạn ở định dạng JSON. Chúng ta có thể thấy từ đường dẫn rằng thông tin người dùng được hiển thị được lấy từ tham số id của chuỗi truy vấn (xem hình bên dưới).

Giờ chúng ta sẽ thử thay đổi ID 1 và 3 để xem có lỗ hỏng IDOR hay không.



Acme IT Support - Customers Dashl ✕ | Settings ✕ | 10-49-164-200.reverse-proxy.ce ✕ | +

10-49-164-200.reverse-proxy.cell-prod-ap-south-1b.vm.tryhackme.com/api/v1/customer?id=1

SON | Dữ liệu thô | Tiêu đề

ưu | Sao chép | Thu gọn tất cả | Mở rộng tất cả | Bộ lọc JSON


```
id:        1
username:  "adam84"
email:     "adam-84@fakemail.thm"
```


What is the username for user id 1?

adam84 | ✓ Correct Answer

10-49-164-200.reverse-proxy.cell-prod-ap-south-1b.vm.tryhackme.com/api/v1/customer?id=3

JSON | Dữ liệu thô | Tiêu đề

Lưu | Sao chép | Thu gọn tất cả | Mở rộng tất cả | Bộ lọc JSON


```
id:        3
username:  "john911"
email:     "j@fakemail.thm"
```


What is the email address for user id 3?

j@fakemail.thm | Loading...